CS-01 TP · BTS SIO 2E ANNÉE · CYBERSÉCURITÉ

# Audit technique d'un poste Linux

Relever l'état de sécurité d'une machine (comptes, privilèges, mots de passe, ports, services, logiciels), puis automatiser le relevé dans un script.


AUTEUR
Constant Segrétain

CONTEXTE
TP en cours, poste Fedora 43

DATE
mars 2026


## Objectif

Produire un état de la machine qui réponde à douze questions d'audit, d'abord à la main, puis avec un script qui génère le rapport en une commande.

## 1. Comptes et privilèges

### Comptes avec l'UID 0

```
grep ':0:0:' /etc/passwd
```

```
constantseg@Laptop-Fedora:~$ grep ':0:0:' /etc/passwd
root:x:0:0:Super User:/root:/bin/bash
```

Seul `root` a l'UID 0. Un autre compte avec cet UID serait un administrateur caché.

### Le fichier /etc/shadow

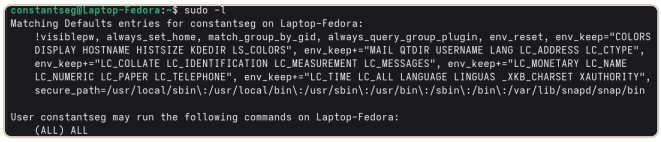
```
constantseg@Laptop-Fedora:~$ sudo cat /etc/shadow
root:!:::::::
bin:!*:20294::::::
daemon:!*:20294::::::
adm:!*:20294::::::
lp:!*:20294::::::
sync:!*:20294::::::
shutdown:!*:20294::::::
halt:!*:20294::::::
mail:!*:20294::::::
operator:!*:20294::::::
games:!*:20294::::::
ftp:!*:20294::::::
nobody:!*:20294::::::
dbus:!*:20384::::::
```

Chaque ligne : nom, empreinte du mot de passe, date du dernier changement, puis les règles d'expiration. `!` ou `*` à la place de l'empreinte signifie qu'on ne peut pas se connecter avec un mot de passe : c'est le cas des comptes système et de `root`, verrouillé.

### Droits sudo et groupe d'administration

```
constantseg@Laptop-Fedora:~$ grep wheel /etc/group
wheel:x:10:constantseg
```

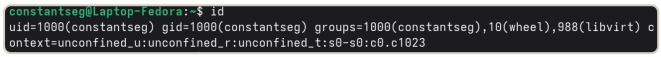
Membres du groupe `wheel`.




`sudo -l` : le compte peut tout exécuter en root.

Sur Fedora, les administrateurs sont les membres du groupe `wheel`. Un seul compte en fait partie.

### Privilèges effectifs et sessions

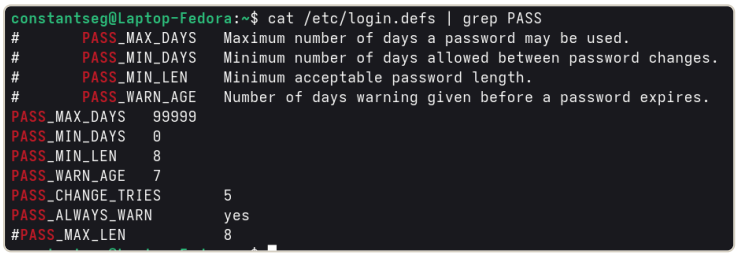



`id`




`who`

## 2. Politique de mots de passe



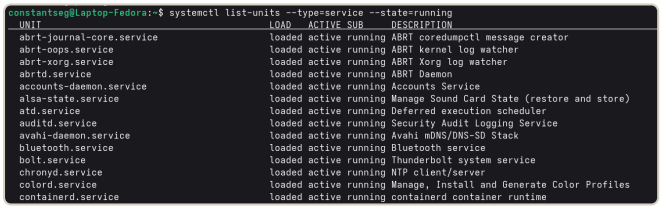

| Paramètre | Valeur | Lecture |
|---|---|---|
| `PASS_MAX_DAYS` | 99999 | Pas d'expiration. |
| `PASS_MIN_LEN` | 8 | Faible ; sur les distributions récentes, la longueur est surtout imposée par PAM ( `pwquality` ). |
| `PASS_WARN_AGE` | 7 | Sans effet tant qu'il n'y a pas d'expiration. |

## 3. Exposition réseau et logiciels

```
constantseg@Laptop-Fedora:~$ netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.54:53           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:631           0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:5355            0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:8384          0.0.0.0:*               LISTEN
tcp6       0      0 :::5355                 :::*                    LISTEN
tcp6       0      0 :::22000                :::*                    LISTEN
tcp6       0      0 ::1:631                 :::*                    LISTEN
udp        0      0 0.0.0.0:5353            0.0.0.0:*
udp        0      0 0.0.0.0:5355            0.0.0.0:*
udp        0      0 0.0.0.0:38290           0.0.0.0:*
udp        0      0 127.0.0.54:53           0.0.0.0:*
udp        0      0 127.0.0.53:53           0.0.0.0:*
udp        0      0 127.0.0.1:323           0.0.0.0:*
udp        0      0 0.0.0.0:51250           0.0.0.0:*
udp        0      0 0.0.0.0:37151           0.0.0.0:*
udp        0      0 0.0.0.0:21027           0.0.0.0:*
udp6       0      0 :::5353                 :::*
udp6       0      0 :::5355                 :::*
udp6       0      0 :::22000                :::*
udp6       0      0 :::59927                :::*
udp6       0      0 ::1:323                 :::*
udp6       0      0 :::21027                :::*
```

`netstat -tuln` : ports en écoute.

La plupart des services n'écoutent que sur `127.0.0.1` (DNS local, impression), donc injoignables depuis le réseau. Ceux qui écoutent sur toutes les interfaces ( `0.0.0.0` ou `::` ), comme le port 5355 (LLMNR) et 22000 (Syncthing), sont à justifier ou à fermer.



```
constantseg@Laptop-Fedora:~$ systemctl list-units --type=service --state=running
  UNIT                                LOAD   ACTIVE SUB     DESCRIPTION
  abrt-journal-core.service           loaded active running ABRT coredumpctl message creator
  abrt-oops.service                   loaded active running ABRT kernel log watcher
  abrt-xorg.service                   loaded active running ABRT Xorg log watcher
  abrtd.service                       loaded active running ABRT Daemon
  accounts-daemon.service             loaded active running Accounts Service
  alsa-state.service                  loaded active running Manage Sound Card State (restore and store)
  atd.service                         loaded active running Deferred execution scheduler
  auditd.service                      loaded active running Security Audit Logging Service
  avahi-daemon.service                loaded active running Avahi mDNS/DNS-SD Stack
  bluetooth.service                   loaded active running Bluetooth service
  bolt.service                        loaded active running Thunderbolt system service
  chronyd.service                     loaded active running NTP client/server
  colord.service                      loaded active running Manage, Install and Generate Color Profiles
  containerd.service                  loaded active running containerd container runtime
```

Services démarrés.

```
constantseg@Laptop-Fedora:~$ cat /etc/os-release
NAME="Fedora Linux"
VERSION="43 (Workstation Edition)"
RELEASE_TYPE=stable
ID=fedora
VERSION_ID=43
VERSION_CODENAME=""
PRETTY_NAME="Fedora Linux 43 (Workstation Edition)"
ANSI_COLOR="0;38;2;60;110;180"
LOGO=fedora-logo-icon
CPE_NAME="cpe:/o:fedoraproject:fedora:43"
DEFAULT_HOSTNAME="fedora"
HOME_URL="https://fedoraproject.org/"
DOCUMENTATION_URL="https://docs.fedoraproject.org/en-US/fedora/f43/"
SUPPORT_URL="https://ask.fedoraproject.org/"
BUG_REPORT_URL="https://bugzilla.redhat.com/"
REDHAT_BUGZILLA_PRODUCT="Fedora"
REDHAT_BUGZILLA_PRODUCT_VERSION=43
REDHAT_SUPPORT_PRODUCT="Fedora"
REDHAT_SUPPORT_PRODUCT_VERSION=43
SUPPORT_END=2026-12-02
VARIANT="Workstation Edition"
VARIANT_ID=workstation
```

Version du système.

## 4. Le script d'audit

Les douze relevés sont regroupés dans un script qui écrit `rapport.txt` . Le même audit peut ainsi être rejoué sur une autre machine, ou après des corrections pour comparer.

```
#!/bin/bash
{
echo "1. Comptes disposant d'un UID 0 :";        grep ':0:0:' /etc/passwd; echo
echo "2. Comptes et état des mots de passe :";  sudo awk -F: '{print $1, substr($2,1,3)}'
```

```
/etc/shadow; echo
echo "3. Permissions sudo du compte courant :"; sudo -l; echo
echo "4. Liste des comptes locaux :";           cat /etc/passwd; echo
echo "5. Membres du groupe d'administration :"; grep wheel /etc/group; echo
echo "6. Politique de mots de passe :";         grep ^PASS /etc/login.defs; echo
echo "7. Sessions actives :";                   who; echo
echo "8. Privilèges du compte courant :";       id; echo
echo "9. Ports ouverts et protocoles :";        ss -tuln; echo
echo "10. Services en cours d'exécution :";     systemctl list-units --no-pager --type=service --
state=running; echo
echo "11. Logiciels installés :";               dnf list --installed; echo
echo "12. Version du système :";                cat /etc/os-release; hostnamectl
} > rapport.txt
```

Par rapport à la première version, le point 2 n'écrit plus les empreintes complètes dans le rapport, seulement leur début (type d'algorithme ou verrouillage) : un rapport d'audit ne doit pas devenir lui-même une fuite de données. `ss` remplace `netstat`, qui n'est plus installé par défaut.